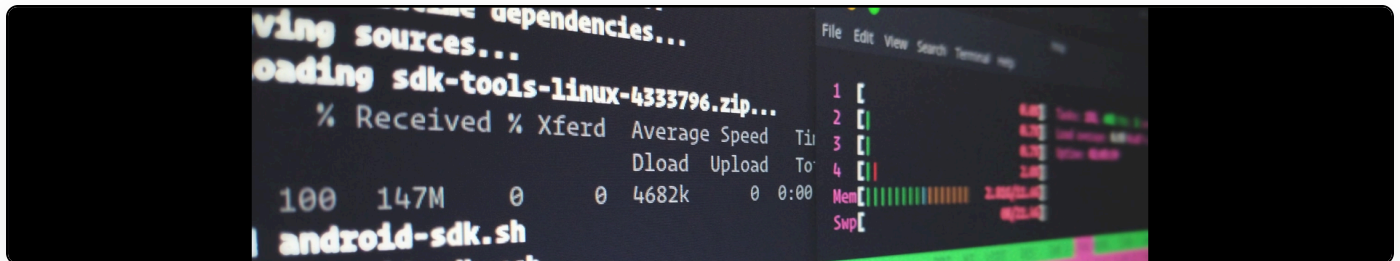


.NETIDS can now detect fragmented XSS

Cite as: Martin Paul Eve, ".NETIDS can now detect fragmented XSS", *eve.gd: Martin Paul Eve*, June 15, 2007, <https://doi.org/10.59348/p5r60-2gk97>.



Today I made some large commits to the [.NETIDS project](#) to enable detection of fragmented XSS attacks.

For an example of what a fragmented attacks looks like, have a look at the .NETIDS SmokeTest. The following url illustrates a fragmented XSS attack:

```
<a href="http://www.the-mice.co.uk/SmokeTest/SmokeTest.aspx?
param1=Hello%20&param2=this%20&param3=is%20a%20test!">http://www.the-
mice.co.uk/SmokeTest/SmokeTest.aspx?
param1=Hello%20&param2=this%20&param3=is%20a%20test</a>
```

As you can see, the resulting markup on the page contains a concatenation of param1, param2 and param3:

```
fragmented input: Hello this is a test!
```

The essence of a fragmented XSS attack is to use this to construct a string from the various concatenations that performs a malicious action. For example, I might try to inject "<" as parameter 1, "script" as parameter 2 and ">" as parameter 3. This is traditionally very hard to detect

because you'd have to permutate through every combination of the strings to see if they form an attack. However, the .NET Framework provides a mechanism for intercepting the rendering of the page and this is the approach taken by .NETIDS.

Step 1: Create an OutputFilter and attach it to Response.Filter:

```
_oF = new OutputFilter(Response.Filter, this, System.Text.Encoding.ASCII,
Server.MapPath("~/IDS/output_filter.xml"));
_oF.OnPageReady += new OutputFilter.PageReadyEvent(_oF_OnPageReady);
Response.Filter = _oF;
```

Step 2: Write code to take action inside the specified delegate (_oF_OnPageReady)

```
void _oF_OnPageReady(OutputFilter oF)
{
    //Here you can access oF.Report for an IDS report and then either call:
    oF.WriteResponse();

    //which will write out the original page output
    //or
    oF.WriteResponse(string);
    //which allows you to specify an entirely new page output
}
```

Pretty nifty huh?

The output filtering has to operate on a smaller set of rules as it must allow most HTML elements but still offers a safeguard against fragmented XSS attacks.

Last but not least, here's a live illustration of page output being caught:

[http://www.the-mice.co.uk/SmokeTest/SmokeTest.aspx?
param1=%3C¶m2=script¶m3=%3E](http://www.the-mice.co.uk/SmokeTest/SmokeTest.aspx?param1=%3C¶m2=script¶m3=%3E)

**NOTE WELL: THE .NETIDS PROJECT IS CURRENTLY ON TEMPORARY HOLD AND
FRAGMENTED OUTPUT FILTERING IS DISABLED ON THE SANDBOX TEST**